

Security+ 4.8 · Incident Response

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 4.8** —
Incident Response (9:14) · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: NIST Incident Response: Preparation → Detection/Analysis → Containment → Eradication → Recovery → Lessons Learned. Containment FIRST (isolate before cleaning). Lessons Learned feeds back into Preparation.

High-Yield Core Concepts Tested on Exam

- Preparation → Detection → Containment → Eradication → Recovery → Lessons Learned
- CONTAINMENT first: isolate spread BEFORE cleaning
- Lessons Learned feeds back into Preparation
- Detection/Analysis: identify and assess the incident
- Eradication: remove the threat; Recovery: restore operations

Exam Tips & Classic Scenarios

- 'isolates affected systems to prevent spread' = Containment
- 'first step after detection' = Containment
- 'post-incident review' = Lessons Learned

Typical Exam Scenario: 'attack detected: first action is to isolate from network' = containment.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 4.8 — Incident Response)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. In the NIST incident response order, what comes FIRST?

- A)** Eradication
- B)** Preparation
- C)** Recovery
- D)** Containment

2. According to NIST, what is the first phase of the incident response cycle?

- A)** Detection and Analysis
- B)** Preparation
- C)** Containment
- D)** Recovery

3. In digital forensics, what is the chain of custody?

- A)** Type of disk encryption
- B)** Documentation of evidence handling
- C)** Forensic backup method
- D)** Malware analysis tool

4. Corporate scenario (Incident Response): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.8), an analyst evaluates the following technical requirement: 'Preparation → Detection → Containment → Eradication → Recovery → Lessons Learned'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: Preparation → Detection → Containment → Eradication → Recovery → Lessons Learned
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

5. Corporate scenario (Incident Response): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.8), an analyst evaluates the following technical requirement: 'CONTAINMENT first: isolate the spread BEFORE cleaning.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: CONTAINMENT first: isolate the spread BEFORE cleaning...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

6. Corporate scenario (Incident Response): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.8), an analyst evaluates the following technical requirement: 'Lessons Learned feeds back into Preparation'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Lessons Learned feeds back into Preparation...
- D)** Allow shared access among administrators with generic credentials

7. Corporate scenario (Incident Response): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.8), an analyst evaluates the following technical requirement: 'isolates affected systems to prevent spread' = Containment. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: 'isolates affected systems to prevent spread' = Containment.

8. Corporate scenario (Incident Response): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.8), an analyst evaluates the following technical requirement: 'attack detected: first action is to isolate from the network'=containment.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'attack detected: first action is to isolate from the network'=containment....
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

9. Corporate scenario (Incident Response): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.8), an analyst evaluates the following technical requirement: 'Preparation → Detection → Containment → Eradication → Recovery → Lessons Learned'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Preparation → Detection → Containment → Eradication → Recovery → Lessons Learned
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

10. Corporate scenario (Incident Response): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.8), an analyst evaluates the following technical requirement: 'CONTAINMENT first: isolate the spread BEFORE cleaning'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: CONTAINMENT first: isolate the spread BEFORE cleaning...
- D)** Allow shared access among administrators with generic credentials

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) B — Preparation.

✓ **Why it's correct:** According to NIST SP 800-61, the incident response cycle consists of four main phases: Preparation; Detection and Analysis; Containment, Eradication, and Recovery; and Post-Incident Activity. The first phase is Preparation, which involves establishing policies, procedures, training, and tools before an incident occurs. CompTIA Security+ adopts this order and emphasizes that without proper preparation, subsequent phases are compromised. Therefore, 'Preparation' comes first.

✗ **Why the others are wrong:**

- *Eradication:* Eradication is the phase where the root cause of the incident is removed, such as deleting malware or patching vulnerabilities. It occurs after containment, not before. In the NIST cycle, eradication is part of the third phase (Containment, Eradication, and Recovery). Therefore, it is not the first step. Preparation must precede any reactive action.
- *Recovery:* Recovery is the phase of restoring systems and data to normal operation after eradication. It is a step after containment and eradication. In NIST, recovery is included in the third phase. It cannot be first because it depends on prior actions of preparation, detection, and containment.
- *Containment:* Containment is the phase of limiting the scope and impact of the incident, preventing it from spreading. It is a critical step, but it occurs after detection and analysis, and before eradication. In NIST, containment is part of the third phase. The first phase is always preparation, which precedes any incident. Therefore, containment is not first.

2) B — Preparation.

✓ **Why it is correct:** The correct answer is 'Preparation'. According to NIST SP 800-61 (Computer Security Incident Handling Guide), the incident response cycle consists of four phases: Preparation; Detection and Analysis; Containment, Eradication, and Recovery; and Post-Incident Activity. The first phase, Preparation, is fundamental and occurs before any incident happens. It involves establishing policies, procedures, team training, acquiring tools (SIEM, EDR, forensics), defining communication channels, and creating response plans. Without adequate preparation, subsequent phases are compromised. CompTIA Security+ emphasizes that preparation is the foundation for effective response and must be continuous, including exercises and simulations.

✗ **Why the others are wrong:**

- *Detection and Analysis:* This is the second phase of the NIST incident response cycle. It occurs after preparation and involves monitoring, identifying, and validating the occurrence of an incident, as well as analyzing its scope and impact. Although crucial, it is not the first phase because it depends on resources, procedures, and training established during preparation. Detection and analysis can only be effective if there is a prepared foundation to collect logs, correlate events, and interpret alerts.
- *Containment:* Containment is part of the third phase of the cycle (Containment, Eradication, and Recovery). Its goal is to limit damage and prevent the spread of the incident by isolating affected systems. However, containment can only be executed after the incident has been detected and analyzed, and it depends on plans and resources defined in the preparation phase. Therefore, it is not the first phase but a reactive step that occurs during the incident.
- *Recovery:* Recovery also integrates the third phase of the cycle, after containment and eradication. It consists of restoring affected systems and services to normal operation, validating that the threat has been eliminated, and monitoring to ensure no reinfection. Like containment,

recovery is a step after detection and analysis and depends on prior preparation, such as backups and continuity plans. It is not the first phase of the incident response cycle.

3) B — Documentation of evidence handling.

✓ **Why it is correct:** The chain of custody is the chronological, documented, and auditable record of the entire lifecycle of digital evidence: who collected it, when, where, how, under what conditions, who handled it, where it was transferred, and how it was stored. In a forensic context, it is the mechanism that ensures the integrity, authenticity, and admissibility of evidence in court, allowing tracking of anyone who had contact with the material and demonstrating that no tampering, contamination, or substitution occurred. CompTIA Security+ emphasizes that the chain of custody is a legal and procedural requirement, not a technical tool, and that its breach can invalidate all evidence.

✗ **Why the others are wrong:**

- *Type of disk encryption:* Disk encryption is a data-at-rest protection technique that encodes hard drive sectors (e.g., BitLocker, LUKS, FileVault) to prevent unauthorized access if the device is lost or stolen. It is unrelated to evidence handling documentation; it is a confidentiality control, whereas the chain of custody is an integrity and legal accountability control. Confusing the two concepts completely deviates from the forensic scope.
- *Forensic backup method:* Forensic backup refers to creating a bit-by-bit copy (forensic image) of media, preserving metadata and unallocated sectors, often using tools like dd, FTK Imager, or EnCase. Although imaging is an important collection step, it is not the chain of custody itself; the chain is the documentary record that accompanies that image and all subsequent actions. A backup without custody documentation has no probative value.
- *Malware analysis tool:* Malware analysis tools (e.g., IDA Pro, Ghidra, Cuckoo Sandbox) are used for reverse engineering, behavioral analysis, and extraction of indicators of compromise. They belong to the examination or forensic analysis phase, not the evidence preservation and documentation phase. The chain of custody is an administrative and legal process that precedes and accompanies any technical analysis, independent of the type of tool used.

4) B — Implement the corresponding solution: Preparation → Detection → Containment → Eradication → Recovery → Lessons Learned.

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.8 (Incident Response): Preparation → Detection → Containment → Eradication → Recovery → Lessons Learned. This sequence represents the standard incident response lifecycle, ensuring a structured and effective approach to managing security incidents.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

5) B — Implement the corresponding solution: CONTAINMENT first: isolate the spread BEFORE cleaning....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for

lesson 4.8 (Incident Response): CONTAINMENT first: isolate the spread BEFORE cleaning. During incident response, containment is a critical phase that prevents further damage and spread before eradication and recovery. The correct action is to implement the corresponding containment strategy.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

6) C — Implement the corresponding solution: Lessons Learned feeds back into Preparation....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.8 (Incident Response): Lessons Learned feeds back into Preparation. The Incident Response lifecycle includes Preparation, Detection and Analysis, Containment, Eradication, Recovery, and Lessons Learned. The Lessons Learned phase involves reviewing the incident to identify improvements, which are then used to enhance the Preparation phase (e.g., updating policies, procedures, training, and tools). This creates a continuous improvement loop, making the organization better prepared for future incidents.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

7) D — Implement the corresponding solution: 'isolates affected systems to prevent spread' = Containment..

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.8 (Incident Response): 'isolates affected systems to prevent spread' = Containment. Containment is the incident response phase where the spread of an incident is limited by isolating affected systems, preventing further damage.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.

- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

8) B — Implement the corresponding solution: 'attack detected: first action is to isolate from the network'=containment.....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.8 (Incident Response): 'attack detected: first action is to isolate from the network'=containment. Containment is the phase of incident response where the goal is to limit the scope and impact of an incident, often by isolating affected systems from the network to prevent further spread.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

9) A — Implement the corresponding solution: Preparation → Detection → Containment → Eradication → Recovery → Lessons Learned.

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.8 (Incident Response): Preparation → Detection → Containment → Eradication → Recovery → Lessons Learned. This is the standard incident response lifecycle, ensuring a structured approach to handling security incidents.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

10) C — Implement the corresponding solution: CONTAINMENT first: isolate the spread BEFORE cleaning....

✓ **Why it is correct:** According to the official CompTIA Security+ exam objectives (SY0-701) for lesson 4.8 (Incident Response): CONTAINMENT first: isolate the spread BEFORE cleaning. The containment phase limits the scope and impact of an incident before eradication and recovery, preventing further damage.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks

compliance standards (PCI DSS, ISO 27001).

- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.